

INTERNAL POLICY: THIRD-PARTY VENDOR ONBOARDING

Policy Number: POL-VENDOR-003 | Effective Date: March 1, 2026 | Owner: Legal Operations and Compliance

1. Purpose

This policy establishes the minimum due-diligence, contractual, and data-protection requirements that must be satisfied before any third-party vendor is onboarded for services involving access to company systems, data, or facilities.

2. Scope

This policy applies to all business units engaging third-party vendors, contractors, or service providers, regardless of contract value, where the vendor will access company data, systems, or premises.

3. Vendor Risk Classification

Vendors must be classified as Low, Medium, or High risk based on the sensitivity of data accessed, criticality of the service to business operations, and geographic location of vendor operations. High-risk vendors require additional security review and executive sign-off prior to contract execution.

4. Mandatory Contractual Provisions

All vendor contracts must include: a data protection clause aligned with applicable privacy law, a limitation-of-liability clause capping exposure at no less than twelve months of fees, a termination-for-convenience right, confidentiality obligations surviving termination by at least five years, and audit rights for High-risk vendors.

5. Escalation Requirements

Any vendor contract that fails to meet the mandatory provisions in Section 4, or that contains an uncapped liability clause, missing termination rights, or one-sided indemnification, must be escalated to senior legal counsel before execution.

6. Review Cadence

High-risk vendor contracts must be reviewed annually. Medium and Low-risk vendor contracts must be reviewed at renewal or every two years, whichever is sooner.

7. Non-Compliance

Any business unit that onboards a vendor without following this policy is subject to review by the Compliance function and may be required to renegotiate or terminate the non-compliant agreement.